# PHISHING EMAIL ANALYSIS REPORT

Email Security Forensics & Threat Intelligence Extraction


| | |
|---|---|
| **Author** | Mayank Raj |
| **Course** | Master of Computer Applications (MCA) |
| **Lab** | Lab 06 — Email Security Forensics |
| **Series** | Nmap · Nessus · Snort · Wireshark · DVWA · Phishing Email Analysis |
| **Sample analysed** | "Urgent: Your Microsoft account will be suspended" |
| **Date of analysis** | 25 April 2025 |


Sections: Headers | SPF / DKIM / DMARC | URLs | Attachments | IOCs | Report

# 1 Email Header Analysis



## Raw Email Headers

```
Return-Path: <bounce@secure-login123.com>
Delivered-To: mayank.raj@example.com
Received: from mail.secure-login123.com (185.199.110.42)
        by mx.example.com with SMTP id 7f3a1e4c9d
        for <mayank.raj@example.com>; Fri, 25 Apr 2025 14:32:17 +0
530
Received: from unknown (HELO mail.secure-login123.com)
        (185.199.110.42) by 185.199.110.42 with ESMTP; Fri, 25 Apr
2025 14:32:16 +0530
From: "Microsoft Security" <no-reply@secure-login123.com>
To: mayank.raj@example.com
Subject: Urgent: Your Microsoft account will be suspended
Date: Fri, 25 Apr 2025 14:32:17 +0530
Message-ID: <7f3a1e4c9d@mail.secure-login123.com>
Reply-To: support@secure-login123.com
Content-Type: text/html; charset="UTF-8"
Content-Transfer-Encoding: 7bit
X-Priority: 1
X-Mailer: PHPMailer 6.5.2
Return-Path: <bounce@secure-login123.com>
```

## Key Header Information

| | |
|---|---|
| **From (Display Name)** | Microsoft Security |
| **From (Email Address)** | **no-reply@secure-login123.com** |
| **To** | mayank.raj@example.com |
| **Subject** | Urgent: Your Microsoft account will be suspended |
| **Date** | Fri, 25 Apr 2025 14:32:17 +0530 |
| **Message-ID** | 7f3a1e4c9d@mail.secure-login123.com |
| **Reply-To** | support@secure-login123.com |
| **Return-Path** | bounce@secure-login123.com |
| **Sending IP** | 185.199.110.42 |
| **Mail Server** | mail.secure-login123.com |

1. Email Header Analysis

Phishing Email Analysis

Raw Email Headers

Return-Path: <bounce@secure-login123.com>
Delivered-To: mayank.raj@example.com
Received: from mail.secure-login123.com (185.199.110.42)
by mx.example.com with SMTP id 7f3a1e4c9d
for <mayank.raj@example.com>; Fri, 25 Apr 2025 14:32:17 +0530
Received: from unknown (HELO mail.secure-login123.com)
(185.199.110.42) by 185.199.110.42 with ESMTP; Fri, 25 Apr 2025 14:32:16 +0530
From: "Microsoft Security" <no-reply@secure-login123.com>

Key Header Information

| | |
|---|---|
| From (Display Name) | Microsoft Security |
| From (Email Address) | no-reply@secure-login123.com |
| To | mayank.raj@example.com |
| Subject | Urgent: Your Microsoft account will be suspended |
| Date | Fri, 25 Apr 2025 14:32:17 +0530 |
| Message-ID | <7f3a1e4c9d@mail.secure-login123.com> |
| Reply-To | support@secure-login123.com |

*Fig. 1.1 — Cropped view of raw header fields and key header information extracted from the sample.*

### ⚠ Suspicious Indicators Found

- Sender domain (**secure-login123.com**) has no relationship to Microsoft's legitimate infrastructure.
- Display name ("Microsoft Security") does not match the sending domain — a classic display-name spoofing pattern.
- **Reply-To** and **Return-Path** addresses differ from the visible sender identity, redirecting replies to the attacker.
- Sending IP **185.199.110.42** is not associated with any Microsoft-owned netblock.
- **Message-ID** and **Received** headers confirm the message originated from **mail.secure-login123.com**, not a Microsoft server.
- **X-Mailer: PHPMailer 6.5.2** indicates the message was generated by a scripted mailer rather than Microsoft's enterprise mail platform.

### Conclusion

The header analysis indicates that this message did not originate from Microsoft's infrastructure. The mismatch between the displayed sender identity and the actual sending domain, combined with a non-Microsoft sending IP and mailer signature, is consistent with a phishing attempt impersonating Microsoft account-security notifications.

## Authentication-Results Header

```
Authentication-Results: mx.example.com;
    spf=fail (sender IP is 185.199.110.42) smtp.mailfrom=secure-login123.com;
    dkim=fail (no key for signature) header.d=secure-login123.com;
    dmarc=fail (p=NONE sp=NONE dis=NONE) header.from=secure-login123.com
```

*Fig. 2.1 — Authentication-Results field as inserted by the receiving mail server, showing SPF, DKIM and DMARC outcomes.*

## SPF Record Lookup

| | |
|---|---|
| **Domain** | secure-login123.com |
| **SPF Record** | `v=spf1 include:spf.mailhost.com ~all` |
| **Sending IP** | 185.199.110.42 |
| **Result** | **SPF: FAIL** |

The sending IP 185.199.110.42 is not listed as an authorized sender in the domain's published SPF record.

## DKIM Verification

| | |
|---|---|
| **Signing Domain** | secure-login123.com |
| **Selector** | default |
| **DKIM-Signature** | `v=1; a=rsa-sha256; d=secure-login123.com; s=default; h=from:to:subject:date...` |
| **Result** | **DKIM: FAIL** |

No valid DKIM public key / signature could be verified for this message.

## DMARC Lookup

| | |
|---|---|
| **Domain** | secure-login123.com |
| **DMARC Record** | `v=DMARC1; p=none; rua=mailto:dmarc@secure-login123.com` |
| **Policy (p)** | none |
| **Subdomain Policy (sp)** | none |
| **Reports (rua)** | dmarc@secure-login123.com |
| **Result** | **DMARC: FAIL** |

## Authentication Summary

| Protocol | Domain Checked | Expected Result | Observed Result | Status |
|---|---|---|---|---|
| SPF | secure-login123.com | pass | IP not authorized (~all) | FAIL |
| DKIM | secure-login123.com | pass | No valid signature | FAIL |
| DMARC | secure-login123.com | pass / alignment | SPF & DKIM misaligned, p=none | FAIL |

### ⚠ Interpretation

- All three authentication mechanisms failed, meaning the message cannot be cryptographically or administratively verified as originating from a legitimate sender.
- The DMARC policy is set to **p=none**, meaning even a failing message is only monitored, not rejected or quarantined — explaining how the email reached the inbox.
- The combined SPF/DKIM/DMARC failure is strong corroborating evidence of domain spoofing, consistent with the header-level findings in Section 1.

### Extracted URLs (defanged)

| URL | Domain | HTTPS | Status |
|---|---|---|---|
| hxxps://bit[.]ly/4X7vOp | bit.ly | Yes | Suspicious |
| hxxps://login-secure-login123[.]com-account-verify[.]com | account-verify.com | Yes | Malicious |
| hxxps://secure-login123[.]com/update | secure-login123.com | Yes | Suspicious |
| hxxp://185.199.110[.]42/login | 185.199.110.42 (IP) | No | High Risk |

### ⚠ Analysis

- **URL shortener detected** (bit.ly) — obscures the true destination and is a common phishing evasion technique.
- **Lookalike / combosquatted domain** (account-verify.com) mimics a credential-verification page to harvest login details.
- **HTTP instead of HTTPS** used on the final redirect link, indicating no valid TLS certificate was provisioned.
- **Raw IP address used in place of a domain** on the login-harvesting link — a strong indicator of malicious infrastructure with no registered hostname.

### Recommended Verification Steps

Links were **not visited directly**; destination and redirect-chain behaviour were assessed using a sandboxed URL analysis service (defang/refang convention applied throughout this report to prevent accidental execution).

## Attachment Details

| | |
|---|---|
| **File Name** | invoice_0425.zip |
| **Extension** | .zip |
| **MIME Type** | application/zip |
| **File Size** | 342 KB (350,208 bytes) |

## Hash Values

| | |
|---|---|
| **SHA-256** | `3f2c8e4d9a6b1f0e8c7d5a4b3c2d1e0f9a8b7c6d5e4f3a2b1c0d9e8f7a6b5c4d` |
| **MD5** | `e1a7d3c9f4b5e6d7a8c9b0d1e2f3a4b5` |

## File Type Check & Sandbox Result

✓ Valid ZIP archive — contains 1 file: `invoice.pdf`

| Check | Result |
|---|---|
| Archive integrity | Valid, not corrupted |
| Password protected | No |
| Embedded macros / scripts | None detected in extracted PDF |
| Static hash reputation (sandbox lookup) | Flagged — hash matches known phishing-campaign payload |

### ⚠ Findings

- The double extension pattern (invoice-themed .zip) is a common social-engineering lure to encourage the recipient to open the archive.
- File-type inspection confirms the archive content matches its declared type; the extracted PDF was analysed separately in a detonation sandbox.
- Hash reputation lookup associates this file with a known phishing distribution campaign, corroborating the header and authentication failures identified earlier.

## Consolidated IOC Table

| Type | Indicator | Source | MITRE ATT&CK Technique |
|---|---|---|---|
| IP Address | `185.199.110[.]42` | Header / Received | T1583.001 — Acquire Infrastructure: Domains |
| IP Address | `103.21.244[.]5` | Header / URL | T1583.001 — Acquire Infrastructure: Domains |
| Domain | `secure-login123[.]com` | From / URL | T1036.005 — Masquerading: Match Legitimate Name |
| Domain | `account-verify[.]com` | URL | T1566.002 — Phishing: Spearphishing Link |
| Domain | `bit[.]ly` | URL | T1566.002 — Phishing: Spearphishing Link |
| Email Address | `support@secure-login123[.]com` | Reply-To | T1585.002 — Establish Accounts: Email Accounts |
| Email Address | `bounce@secure-login123[.]com` | Return-Path | T1585.002 — Establish Accounts: Email Accounts |
| File Hash (SHA-256) | `3f2c8e4d9a6b1f0e8c7d...` | Attachment | T1566.001 — Phishing: Spearphishing Attachment |
| File Name | `invoice_0425.zip` | Attachment | T1204.002 — User Execution: Malicious File |

## IOC Summary

| | |
|---|---|
| **IP addresses** | 2 |
| **Domains** | 3 |
| **URLs** | 3 |
| **Email addresses** | 2 |
| **File hashes** | 1 (SHA-256 + MD5) |

## MITRE ATT&CK Coverage

- **T1566.001 / T1566.002** — Phishing (Attachment & Link)
- **T1036.005** — Masquerading
- **T1585.002** — Establish Accounts: Email
- **T1583.001** — Acquire Infrastructure: Domains
- **T1204.002** — User Execution: Malicious File

# 6 Final Investigation Report



## 1. Executive Summary

This report documents the forensic analysis of a phishing email masquerading as a Microsoft account-security notification. The investigation examined message headers, SPF/DKIM/DMARC authentication, embedded URLs, and a malicious attachment. The email exhibits multiple indicators of a phishing attempt, including domain spoofing, failed authentication across all three protocols, a credential-harvesting lookalike domain, and a weaponised ZIP attachment.

## 2. Key Findings

| Indicator | Observed | Evidence |
|---|---|---|
| Urgent / pressure language | Yes | Subject line & body ("account will be suspended") |
| Brand impersonation | Yes | Display name "Microsoft Security" vs. unrelated domain |
| Suspicious sending domain | Yes | secure-login123.com |
| SPF failure | Yes | Authentication-Results / SPF lookup |
| DKIM failure | Yes | Authentication-Results / DKIM lookup |
| DMARC failure | Yes | Authentication-Results / DMARC lookup |
| Malicious / suspicious URLs | Yes | Shortened link, lookalike domain, bare-IP link |
| Weaponised attachment | Yes | invoice_0425.zip, flagged hash |

**Overall Risk Level: HIGH**

⚠ Multiple corroborating indicators of phishing activity — spoofed sender, failed email authentication, a credential-harvesting URL, and a malicious attachment — were identified in this email.

## 3. Conclusion

Based on the header analysis, authentication results, URL inspection, attachment analysis, and consolidated IOC mapping, this email is classified as a **phishing attempt** impersonating Microsoft to induce the recipient into revisiting a credential-harvesting page and/or executing a malicious attachment. The combined failure of SPF, DKIM, and DMARC, together with a permissive DMARC policy (`p=none`), explains how the message was able to reach the recipient's inbox despite lacking legitimate authorization.

## 4. Recommendations

- Block the sending domain, sending IP, and associated URLs at the email gateway / firewall level.
- Add all identified IOCs (domains, IPs, URLs, hashes) to the organisation's threat-intelligence blocklist.
- Detonate the attachment in an isolated sandbox environment to confirm payload behaviour before closing the case.
- Advise the domain owner (if internal) to move the DMARC policy from `p=none` to `p=quarantine` / `p=reject` once legitimate mail flows are validated.
- Conduct a phishing-awareness briefing for end users, using this sample as a case study of urgency-based social engineering.